Project Compass AI Governance Policy

This policy describes how Compass governs its own use of artificial intelligence, including the Claude powered "Explain This Finding" feature, in alignment with the NIST AI Risk Management Framework and the OWASP Top 10 for LLM Applications (2025).

Document: AI Governance Policy, Project Compass Platform

Version: 1.0

Effective: July 2026

Owner: Compass Security and Compliance Team

Review Cycle: Quarterly

What the AI Feature Does

The "Explain This Finding" button appears alongside flagged NIST AI RMF controls on the dashboard. When selected, Compass sends a small, structured piece of information to the Anthropic API, using Claude Haiku, and receives a concise, plain language explanation of the gap along with three recommended remediation steps. This feature currently operates only in local environments and will not be available in the standard Vercel deployment unless the appropriate environment variable has been configured.

Process flow: The browser (dashboard.html) submits a request to the proxy API (POST /api/explain, handled by serve.mjs), which calls the Anthropic API (claude-haiku-4-5) and returns the explanation for display on the page.

The proxy server, serve.mjs, functions as a gatekeeper. The browser never has direct access to the API key, and the proxy determines exactly which fields are permitted to be transmitted. No session data, log content, organization name, or user identity leaves the local server at any point.

What Is Sent to Anthropic, and What Is Not

Data Field	Sent to Claude?	Classification	Notes
control_id (e.g. GV.PO-1)	Yes	Public standard	A NIST control identifier, not specific to any organization
control_name (e.g. "AI Risk Policy")	Yes	Public standard	A descriptive label drawn from the public NIST framework
status (Gap / Partial / Met)	Yes	Non-identifying	A structural category value, not tied to any organization
finding_text	Yes	Non-identifying	A fixed sentence such as "Control X, Name, is unmet," with no organization name, log content, or user data
Organization name	No	Sensitive, personal	Remains within the browser session only
Log file contents	No	Sensitive, operational	Never leaves the browser; all processing occurs on the user's device
User name or email	No	Sensitive, personal	Remains within the login session and is never included in any request to the API
AI tool inventory	No	Sensitive, operational	Remains within the session and is never included in any server call
NIST gap scores or counts	No	Sensitive, operational	Calculated within the browser and never transmitted

Application of NIST AI RMF to Compass Itself

Compass applies the same standard to its own AI feature that it applies when evaluating a client's AI tools. The following outlines how each relevant control applies to the "Explain This Finding" feature.

GV.PO-1, Govern, AI Risk Policy

This document constitutes Compass's AI use policy for the platform. It defines the scope of the feature, the classification of data involved, accountability for the vendor relationship, and the review cadence.

Status: *Met*

GV.OV-1, Govern, Organizational Oversight

The Compass Security and Compliance Team owns this policy. It is reviewed on a quarterly basis, or whenever the Claude integration, its data handling, or the vendor terms change.

Status: *Met*

GV.AT-1, Govern, AI Awareness

Every explanation generated by the feature includes a disclosure statement identifying it as AI generated and listing exactly what was sent. Users are never left uncertain about whether they are viewing AI generated content.

Status: *Met*

MP.AC-1, Map, Defining the AI's Role

Claude is instructed to operate solely as a concise NIST AI RMF advisor. It is not asked to perform any function outside that role, and no such function is expected of it.

Status: *Met*

MS.MC-1, Measure, Evaluating Trustworthiness

Every explanation is intended to be advisory rather than authoritative. The disclosure statement reminds users to verify AI guidance against official NIST documentation. No automated decisions are made on the basis of Claude's output.

Status: *Partial, advisory use only*

MG.AN-1, Manage, Monitoring for Incidents

Errors returned by the Anthropic API are logged locally. In a production environment, these logs should be routed to a formal monitoring system. Any inaccurate or unexpected output from Claude should be reported to the Compass team.

Status: *Partial, production logging to be established*

Application of the OWASP Top 10 for LLM Applications (2025)

LLM01:2025, Prompt Injection

There is no free text field through which a user can reach the model. All content sent to Claude is drawn from a fixed set of approved fields, constructed server side rather than entered by a user, leaving no opportunity to introduce unauthorized instructions.

Status: *Addressed*

LLM02:2025, Sensitive Information Disclosure

As shown in the data classification table above, no personal information, organization name, log content, or inventory data is transmitted. This restriction is enforced at the server level rather than the browser level.

Status: *Addressed*

LLM03:2025, Supply Chain Risk

Anthropic is a named, contracted vendor. The specific model version, claude-haiku-4-5-20251001, is fixed within the code rather than permitted to update automatically. Vendor risk is reviewed quarterly.

Status: *Addressed*

LLM04:2025, Data and Model Poisoning

Compass does not fine tune Claude or provide feedback that could influence future versions of the model. The integration performs read only inference.

Status: *Not applicable*

LLM05:2025, Improper Output Handling

All output returned by Claude is safely escaped prior to being displayed, preventing execution as code. The only formatting permitted is bold text, converted from simple markdown.

Status: *Addressed*

LLM06:2025, Excessive Agency

Claude has no access to tools, memory, or the ability to take action within this integration. It returns text only, and its output never triggers an automated action.

Status: *Addressed*

LLM07:2025, System Prompt Leakage

The instructions provided to Claude contain no secrets, credentials, or confidential business logic. Their disclosure would not create a security risk.

Status: *Addressed*

LLM08:2025, Vector and Embedding Weaknesses

This feature does not employ a vector database, retrieval pipeline, or embeddings of any kind.

Status: *Not applicable*

LLM09:2025, Misinformation

Every explanation carries a label identifying it as AI generated and advising verification against official NIST documentation. The feature is described as advisory throughout, and never presented as authoritative.

Status: *Residual risk remains*

LLM10:2025, Unbounded Consumption

Each response is limited to 400 tokens. The API key is never exposed to the browser, preventing direct or repeated calls to Anthropic from outside the server.

Status: *Addressed*

Anthropic: Third Party Vendor Assessment

Vendor Name: Anthropic, PBC

Service Used: Anthropic Messages API, Claude Haiku

Model Version: claude-haiku-4-5-20251001

Data Transmitted: NIST control identifiers and descriptions only; no personal or organization specific data

Inherent Risk: Medium

Residual Risk: Low

Vendor Data Handling: Anthropic's API usage policy may retain prompts briefly for safety monitoring purposes. Refer to Anthropic's privacy policy at api.anthropic.com/privacy.

Mitigation: Because only public, standard identifiers are transmitted rather than organization specific data, any information retained by the vendor carries limited sensitivity.

Authentication: The API key is stored in a local .env file excluded from version control, and as an environment variable within Vercel in production. It is never committed to source control.

Next Review: October 2026, in accordance with the quarterly review cycle

Responsible Use Statement

Compass employs artificial intelligence to support human judgment, not to replace it. The "Explain This Finding" feature is intended to help compliance professionals understand a NIST AI RMF control gap more efficiently. It does not serve as a substitute for qualified professional review, legal counsel, or official NIST documentation.

The scope of this AI feature is deliberately limited: a single function, advisory output only, no automated decision-making, and no transmission of sensitive data. This reflects the same standard of responsible AI use that Compass asks its users to apply to their own tools.

Users who observe an explanation that appears inaccurate, unexpected, or unhelpful are encouraged to report it to the Compass team. This feedback is used to refine the instructions provided to Claude or, where appropriate, to disable the feature.

This policy is reviewed on a quarterly basis. Any change affecting the data transmitted, the model in use, or the vendor relationship will be reviewed prior to deployment.